

1/24



File No.: EXP202202685

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On June 1, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against EMAILING NETWORK EUROPE, S.L. (hereinafter, the defendant), through the Agreement that is transcribed:

<<

File No.: EXP202202685

IMI Reference A56ID 340965 Case Register 471773

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On February 14, 2021, the French data protection authority (hereinafter the CNIL) received a complaint from a person, whose data is anonymized (hereinafter the complainant).

The complaint is directed against the entity EMAILING NETWORK SARL.

In their writing, the complainant stated that EMAILING NETWORK SARL is the owner of the website ***WEB.1. Within this website, you can register your email address to receive advertisements by also entering other personal data. Upon unsubscribing from the service, the complainant observed that by entering only their email address, the following data could be accessed: name, surname, postal code, date of birth, gender, and country. It is not necessary to enter any other authentication factor such as a password, which could make the website vulnerable to possible brute force attacks that could extract this personal data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

2/24

SECOND: The investigative actions carried out by the CNIL are as follows:

On July 27, 2021, inspectors from the CNIL visited the establishment in France of the entity EMAILING NETWORK SARL, with the aim of determining compliance with any processing accessible from the domain ***WEB.1 and any organization involved in its implementation within the provisions of the GDPR and the French data protection law.

During the investigations, the CNIL found that in the privacy policy of ***WEB.1, EMAILING NETWORK SARL (French company), EMAILING NETWORK EUROPE (the Spanish parent company), and REWORLD MEDIA (French group to which the EMAILING NETWORK group belongs) are mentioned, without specifying the responsibility of each of them regarding the processing activities. Furthermore, the CNIL states that the EMAILING NETWORK group appears to be primarily located in Spain and its DPO works here. They have also found that the only employee of EMAILING NETWORK SARL who can be located in France is the director, whose contact phone numbers are Spanish. The information provided in the registration form on ***WEB.1 identifies EMAILING NETWORK EUROPE as the data controller.

THIRD: On November 17, 2021, through the "Internal Market Information System" (hereinafter IMI System), regulated by Regulation (EU) No. 1024/2012 of the European Parliament and of the Council of October 25, 2012 (IMI Regulation), whose objective is to promote cross-border administrative cooperation, mutual assistance between Member States, and the exchange of information, France declared itself the lead authority in this matter.

FOURTH: On March 3, 2022, in order to clarify the responsibility for the processing subject to the investigation, the CNIL requested the assistance of the AEPD through the IMI System.

The CNIL provides the following documentation:

- Inspection report conducted at the establishment of EMAILING NETWORK SARL: This report certifies that two agents from the CNIL visited the establishment of EMAILING NETWORK SARL on July 27, 2021. On that date, the representative of EMAILING NETWORK SARL was not present at the establishment as they were on vacation. At the same location, the offices of the company REWORLD MEDIA were present, whose legal representative informed them that EMAILING NETWORK SARL is a company that belongs to the REWORLD MEDIA business group; just as the Spanish company EMAILING NETWORK EUROPE also belonged to the same REWORLD MEDIA group and was the parent company of EMAILING NETWORK SARL. Similarly, the legal representative of REWORLD MEDIA indicated to the CNIL agents that both the employees and the data protection officer of EMAILING NETWORK were located in Spain.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/24

- Diligence of access to the website "URL.1" on July 27, 2021: in this diligence, it is observed that, from this address, a user can be registered by entering the following data: surname, first name, email, date of birth, postal code, country, and gender. The next day (July 28, 2021), it is verified that, from the webpage "URL.2", by entering the data "email", the following information that had been entered the previous day with that "email" can be obtained: email, first name, surname, postal code, country, and date of birth.

- Document submitted by the representative of EMAILING NETWORK SARL, in response to a request for information from the CNIL, dated August 25, 2021, which indicates, among other things, the following information: the data controller of the website "WEB.1" is EMAILING NETWORK EUROPE SL, by virtue of a contract between EMAILING NETWORK SARL and EMAILING NETWORK EUROPE SL.

- Document submitted by the representative of EMAILING NETWORK SARL, in response to a request for information from the CNIL, dated September 13, 2021, which indicates, among other things, the following information:

1. EMAILING NETWORK SARL is the data controller as it determines the purpose of the processed data.

EMAILING NETWORK SARL does not carry out processing operations as they are performed by EMAILING NETWORK EUROPE SL.

EMAILING NETWORK EUROPE SL defines the means of processing and also assumes the role of subcontractor and operates the brand (...) through the site WEB.1.

The processing of the data from the page WEB.1 is carried out by EMAILING NETWORK EUROPE SL.

EMAILING NETWORK EUROPE SL was designated as the contact point for the data subjects.

EMAILING NETWORK SARL receives compensation due to the intervention of EMAILING NETWORK EUROPE SL.

2. Identification of the data protection officer of EMAILING NETWORK EUROPE SL, and indication that they are registered with the AEPD.

3. Capture of a query in the database indicating that there are, among others, the following registered users on the website WEB.1: 8812 active users from Spain (and 412919 inactive users); 5112 active users in Italy (and 148364 inactive users); 667 active users in France (and 31788 inactive users).

4. It is indicated that user data is maintained in the active user database for 120 days. After that time, users are blocked and moved to an inactive database, which is used in case any irregularity needs to be reviewed and for legal liability reasons with public authorities, courts, the prosecutor's office, and data protection control authorities.

5. Indication of the results of EMAILING NETWORK SARL and EMAILING NETWORK EUROPE SL in the years 2018, 2019, and 2020, which together comprise the following amounts: €387,551.93 in 2018;

€67,019.84 in 2019; and €258,942.25 in 2020.

FIFTH: On March 14, 2022, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation proceedings referred to in Article 67 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD) to investigate the facts in question, following the request from the French Control Authority, regarding the cross-border processing of personal data carried out by the entity EMAILING NETWORK EUROPE, S.L.

SIXTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation proceedings to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of the GDPR, and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

A- On October 28, 2022, a written response to a request for information was received at the AEPD, submitted on behalf of EMAILING NETWORK EUROPE SL, which provided the following information:

1. Indication that the responsibilities between EMAILING NETWORK SARL and EMAILING NETWORK EUROPE SL in the processing of personal data are divided as follows, according to the collaboration agreement between both companies:

“a) EMAILING NETWORK SARL is responsible for processing to the extent that it decides on the purpose of the data processed.

b) EMAILING NETWORK SARL does not carry out processing operations as these are performed by EMAILING NETWORK EUROPE SL.

c) EMAILING NETWORK EUROPE, S.L., defines the means of processing and determines how personal data operated by the brand (...) through the website ***WEB.1 should be processed.

d) The processing of data on the website ***WEB.1 is carried out by EMAILING NETWORK EUROPE, S.L.

e) EMAILING NETWORK EUROPE, S.L. has been designated as the contact point for data subjects.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/24

f) In accordance with Articles 1 and 2 of the collaboration contract dated 03/02/2007, EMAILING NETWORK SARL receives compensation through the intervention of EMAILING NETWORK EUROPE S.L.

2. Declaration that “Reworld Media has no involvement in the subsidiary companies EMAILING NETWORK EUROPE, SL and EMAILING NETWORK SARL, as it is limited to capital management for exploitation purposes only. EMAILING NETWORK EUROPE, SL and EMAILING NETWORK SARL have management autonomy, thus carrying out a decentralized management of Reworld Media.” It is indicated that EMAILING NETWORK EUROPE, SL sends a monthly report to Reworld Media that contains only financial data and does not include personal data; a copy of the monthly report is provided, which contains numerical data from various months of 2022.

3. Copy of the Collaboration Agreement between EMAILING NETWORK SARL and EMAILING NETWORK EUROPE SL, signed on February 3, 2007; and an annex with the “DATA PROCESSING JOINT RESPONSIBILITY AGREEMENT FOR THE PROVISION OF SERVICES BY EMAILING NETWORK EUROPE AND THE SUBSIDIARY EMAILING NETWORK SARL,” signed on January 1, 2020. In its section “II. Activities of processing developed concerning personal information,” the following is specified:

“Regarding the categories of data subjects whose data will be processed by the joint controllers:

- By the Joint Controller: EMAILING NETWORK EUROPE, SL

Employees of the joint controller.

Legal representatives and volunteers

Users

ARCO Rights

- By the Joint Controller: EMAILING NETWORK SARL.

Legal representatives and volunteers”

4. Copy of the “DATA PROCESSING RESPONSIBILITY MATRIX PROCEDURE,” in which section “5. Management of processing” distributes the following responsibilities:

“- EMAILING NETWORK EUROPE, S.L

In accordance with the RAT procedure, EMAILING NETWORK EUROPE, S.L performs the following processing as a joint controller:

(...)

- EMAILING NETWORK SARL

In accordance with the activity register of EMAILING NETWORK SARL, performs the following processing:

(...)

B- On October 31, 2022, through the IMI System, via voluntary assistance, the conclusions reached by this AEPD regarding the required assistance were made available to the CNIL, in order to clarify the responsibility for the processing carried out.

C) On December 1, 2022, through the IMI System, within the framework of the same voluntary assistance, the CNIL stated that, after analyzing the documentation obtained from the inspection carried out by the inspectors assigned to this AEPD:

“The French AC has initiated investigations into the processing of data accessible from the domain ‘***WEB.1’. The processing is cross-border (with data subjects in Spain, Italy, France, etc.) and involves at least one Spanish and one French establishment of the group.

At our request, you contacted the Spanish company, identified by the French controller as a joint controller.

After reviewing the responses that the company provided, it seems to us that the Spanish establishment could be the main establishment concerning the processing in the domain ‘***WEB.1’.

The French company is a subsidiary of the Spanish company. The group appears to have several dozen employees, all of whom are in Spain, including the company’s DPO.

Its legal representative is also the representative of the Spanish company. He signed the joint responsibility agreement on behalf of both establishments. The phone numbers provided to us for him are Spanish numbers. The information notices available on the domain ‘***WEB.1’ are in Spanish, or the links leading to them are broken. The Privacy Policy mentions the right to lodge a complaint with a supervisory authority but directs data subjects to the Spanish AC. In response to your questions, the Spanish establishment acknowledges that it defines the means of processing itself and carries out all processing operations. While it once again mentions that the French establishment decides on the purpose of the processing, it does not provide evidence or rational proof of that assertion.

For all these reasons, we do not believe that the French SA is the lead authority regarding this data controller. That is why we would like to ask the Spanish SA to take the initiative in this case. However, if the elements at your disposal demonstrate that the French SA is the lead authority, we are ready to proceed with the case. Our preliminary opinion is that there may be violations at least concerning retention periods (5-1-e), security (5-1-f and 32), and privacy by default (25).”

D) On December 27, 2022, through the IMI System, via a new voluntary assistance, the CNIL was requested to share the original complaint submitted to the French authority.

The French authority transmitted the aforementioned complaint on January 3, 2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/24

In this voluntary assistance, Spain declared itself the main authority in the present matter. The transfer of this matter is carried out in accordance with the provisions of Article 61 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of 27/04/2016, regarding the Protection of Natural Persons with regard to the Processing of Personal Data and the Free Movement of such Data (hereinafter, GDPR), taking into account its cross-border nature and that this Agency is competent to

act as the lead supervisory authority.

The data processing being carried out affects individuals in several Member States. According to the information incorporated into the IMI System, in accordance with the provisions of Article 60 of the GDPR, it acts as an "interested supervisory authority," in addition to the data protection authority of France, and the authorities of Belgium and Italy. All of them under Article 4.22 of the GDPR, given that the individuals residing in the territory of these supervisory authorities are substantially affected or are likely to be substantially affected by the processing subject to this procedure.

From this original complaint, the following information is extracted: the complaint is dated February 14, 2021. In it, the complainant indicates that the website ***URL.2 could contain profiles with personal data such as surname, first name, postal code, date of birth, gender, and country, which could be accessed by merely entering the email address without any other additional authentication factor.

On January 12, 2023, access was made to the website ***WEB.1 and a user was registered by entering the following data: name, surname, email, date of birth, postal code, country, and gender. On January 27, 2023, access was made to the website ***WEB.1, and navigation was done to the page ***URL.3, where the option "Unsubscribe" was accessed, observing the following behavior of the page: A screen appears requesting the entry of an email address, the same address that was registered on January 12, 2023, is entered, and the "SEND" button is clicked, followed by "MODIFY MY PROFILE." Thus, access is granted to a screen where the following data entered during the registration on January 12, 2023, can be seen: email, name, surname, postal code, country, and date of birth. The gender data does not appear selected.

From the query made in the Monitoriza service of Axesor (<https://monitoriza.axesor.es/>) on January 30, 2023, it is obtained that EMAILING NETWORK EUROPE SL is an independent company with a number of employees of 25 and sales of €1,631,450.

SEVENTH: On March 8, 2023, the Director of the AEPD adopted a draft decision to initiate sanctioning proceedings. Following the process established in Article 60 of the GDPR, on March 17, 2023, this draft decision was transmitted via the IMI system, and the interested authorities were informed that they had four weeks from that moment to raise relevant and motivated objections. The processing period of the present sanctioning procedure was automatically suspended during these four weeks, in accordance with the provisions of Article 64.4 of the LOPDGDD.

Within the time frame for this purpose, the interested supervisory authorities did not present relevant and motivated objections in this regard, so it is considered that all authorities agree with this draft decision and are bound by it, in accordance with the provisions of paragraph 6 of Article 60 of the GDPR.

This draft decision, which was notified to EMAILING NETWORK EUROPE in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on March 8, 2023, as stated in the acknowledgment of receipt in the file.

LEGAL GROUNDS

I

Competence and applicable regulations

In accordance with the provisions of Articles 58.2 and 60 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, it is

established that there is a processing of personal data, since EMAILING NETWORK EUROPE, S.L., collects and retains, among others, the following personal data of natural persons: name and surname, date of birth, and email, among other processes.

This is a cross-border processing, given that EMAILING NETWORK EUROPE, S.L. is established in Spain, although it provides services to other countries in the European Union.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/24

The GDPR provides, in its Article 56.1, for cases of cross-border processing, as outlined in its Article 4.23), regarding the competence of the lead supervisory authority, that, without prejudice to the provisions of Article 55, the supervisory authority of the main establishment or the only establishment of the controller or the processor shall be competent to act as the lead supervisory authority for the cross-border processing carried out by such controller or processor in accordance with the procedure established in Article 60.

In the case examined, the French data protection authority, after reviewing the responses of the Spanish company provided following the request made by the inspectors of this AEPD, has pointed out that:

“the Spanish establishment could be the main establishment in relation to the processing in the domain ‘***WEB.1’

The French company is a subsidiary of the Spanish company. The group appears to have several dozen employees, all of whom are in Spain, including the company’s DPO. Its legal representative is also the representative of the Spanish company. He signed the co-responsibility agreement on behalf of both establishments. The phone numbers provided to us for him are Spanish numbers. The information notices available on the domain ‘***WEB.1’ are in Spanish, or the links leading to them are broken. The Privacy Policy mentions the right to lodge a complaint with a supervisory authority but directs interested parties to the Spanish AEPD. In response to their questions, the Spanish establishment acknowledges that it defines the means of processing itself and carries out all processing operations. While it again mentions that the French establishment decides on the purpose of the processing, it does not provide evidence or rational proof of that assertion.

For all these reasons, we do not believe that the French SA is the lead authority with respect to this data controller. That is why we would like to ask the Spanish SA to take the initiative in this case.”

Therefore, as stated, the Spanish Agency for Data Protection declared itself the lead supervisory authority, at the request of the French authority.

For its part, Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter security breach) as “all breaches of security that result in the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

In the present case, there is a personal data security breach under the circumstances outlined above, categorized as a confidentiality breach, as personal data has been exposed.

Within the principles of processing provided in Article 5 of the GDPR, the limitation of the retention period is regulated in paragraph 1.e) of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/24

Article 5 of the GDPR; the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR.

On its part, the security of personal data is regulated in Articles 25 and 32 of the GDPR, which govern data protection by design and by default, and the security of processing, respectively.

III

Limitation of the retention period

Article 5 of the GDPR, concerning the "principles relating to processing," in its paragraph 1.e) establishes:

"1. Personal data shall be:

(...)

e) maintained in a manner that allows the identification of the data subjects for no longer than is necessary for the purposes of the processing of personal data; personal data may be retained for longer periods provided that they are processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, without prejudice to the application of appropriate technical and organizational measures imposed by this regulation to protect the rights and freedoms of the data subject ("limitation of the retention period")."

Furthermore, Recital 39 states:

"All processing of personal data must be lawful and fair. (...) Personal data must be adequate, relevant, and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that their retention period is limited to a strict minimum. Personal data should only be processed if the purpose of the processing cannot reasonably be achieved by other means. To ensure that personal data is not retained longer than necessary, the data controller must establish deadlines for its deletion or periodic review. All reasonable measures must be taken to ensure that inaccurate personal data is rectified or deleted. Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage."

In turn, Recital 65 states:

"Data subjects should have the right to have personal data concerning them rectified and a 'right to be forgotten' if the retention of such data infringes this Regulation or the applicable Union or Member State law concerning the data controller. In particular, data subjects should have the right to have their personal data erased and to stop processing if they are no longer necessary for the purposes for which they were collected or processed in another manner, if the data subjects have withdrawn their consent to processing or object to the processing of personal data concerning them, or if the processing of their personal data otherwise infringes this Regulation. (...)

In this case, once accessed the privacy policy of EMAILING NETWORK EUROPE, through ***WEB.1

"Within the privacy policy, in section 4, concerning 'How long do we keep your data?' it states:

that they only process personal data until consent is withdrawn. Consent can be revoked at any time.

In this case, the data will be automatically blocked to cease processing,

- When rights are exercised, except for the right of rectification.
- once 5 years have passed since the last contact with the data subject.
- automatically, after six months of contact without a response."

On the other hand, as stated by EMAILING NETWORK SARL in its response to the information request made by the CNIL dated September 13, 2021: "user data remains active in the database for 120 days. After that time, users are blocked and moved to a non-active database, which is used in case any irregularity needs to be reviewed, and for legal liability reasons."

That is to say, according to the company's statements, in this case, the privacy policy states that data will be blocked when consent is revoked or, among other reasons, after six months of contact without obtaining a response, while in their response to this AEPD they stated that data remains active for 120 days. In any case, whether the data is retained for 120 days or after six months, it has not been established that the retention period of personal data exceeds the legally permitted period.

Therefore, based on the information provided in the previous paragraphs, no evidence has been found to substantiate the existence of an infringement within the jurisdiction of the Spanish Data Protection Agency regarding the retention period of personal data in this specific case.

IV

Duty of confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/24

its loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").”

In this case, it has been established that on the website ***WEB.1, a profile can be created by filling in the first name and surname, email address, date of birth, postal code, country, and gender.

Once the user is registered, by accessing the website ***URL.2, it is possible to access the data of first name and surname, email address, postal code, country, and date of birth, by entering the email address; that is, no password is required to access such data.

However, it should be noted that the mere identification of a security breach by this Agency does not imply that there has been unauthorized access by third parties to the personal data owned by the data controller. In this case, although the personal data was accessible by simply entering the email address of a registered person, it has not been established that third parties accessed any personal information owned by the data controller.

Therefore, based on the above, no evidence has been found to support the existence of an infringement within the jurisdiction of the Spanish Data Protection Agency regarding the integrity and confidentiality of the data in this case.

V

Data protection by design and by default

Article 25 “Data protection by design and by default” of the GDPR states:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure, in particular, that, by default, personal data are not accessible, without the intervention of the data subject, to an indeterminate number of natural persons.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/24

3. An approved certification mechanism may be used in accordance with Article 42 as a means to demonstrate compliance with the obligations established in paragraphs 1 and 2 of this article.”

This article falls within the general obligations that Chapter IV of the GDPR imposes on the data controller, imposing a design obligation at the time of determining the means of processing, which must effectively ensure compliance with the data protection principles set forth in the general data protection regulations.

In this case, it has been established, both by the French data protection authority on July 28, 2022,

and by the inspectors assigned to this AEPD, through a diligence incorporated into this file on January 27, 2023, that once a user has registered on the website ***WEB.1, and with the mere entry of the email address with which they registered, it is possible to access, from the website ***URL.2, the personal data of the same (name and surname, email address, date of birth, postal code, and country). That is to say, access to this personal data is possible without the need to enter any other information apart from the email address.

Thus, simply by entering the email address used for registration on the ***WEB.1 website, one could access the personal data of the registered individual. Consequently, with this verification, as configured, the registration on this website would have demonstrated that the risks to the rights and freedoms of individuals had not been adequately analyzed, nor had appropriate technical and organizational measures been foreseen or applied from the design stage to effectively implement the data protection principles, such as the confidentiality principle required by Article 25 of the GDPR. In this specific case, the failure to foresee these measures from the design stage could mean that any person entering an email address that was registered could access the personal data without authorization.

For all the above reasons, it is evident that EMAILING NETWORK EUROPE has failed to comply with the design obligation of security measures that ensure the confidentiality of the personal data of individuals registering on the ***WEB.1 website.

In accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to EMAILING NETWORK EUROPE for violation of Article 25 of the GDPR.

VI

Classification of the infringement of Article 25

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/24

If confirmed, the aforementioned infringement of Article 25 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection from the design stage, as well as the failure to integrate the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679. (...)"

VII

Sanction for the infringement of Article 25 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm suffered (paragraph a): for putting at risk and failing to have appropriate measures to ensure compliance with the principles of processing regarding the data of individuals registered on the ***WEB.1 website, (as indicated: 8812 active users from Spain (and 412919 inactive users); 5112 active users in Italy (and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/24

148,364 inactive users); 667 active users in France (and 31,788 inactive users), considering that, since at least February 14, 2021, the date on which the complaint was filed with the CNIL, until at least January 27, 2023, the system for accessing the profile had not been corrected.

- Intentionality/Negligence in the infringement (section b): In this case, EMAILING NETWORK EUROPE would have acted very negligently, since, from at least February 14, 2021, the date of entry of the complaint, until January 27, 2023, the date on which the last check was made, almost two years would have passed without the correct measures being adopted to ensure the security of the personal data owned by the data controller, who would not even have foreseen the possibility that this data could be exposed.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As aggravating factors:

- The link between the infringer's activity and the processing of personal data (section b): it is an entity accustomed to processing personal data.

As mitigating factors:

- Having, when not mandatory, a data protection officer (section g).

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 25 of the GDPR, allows for an initial sanction of €10,000 (ten thousand euros).

VIII

Security Measures

Article 32 “Security of processing” of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or

unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

In this case, it has been established, both by the French data protection authority on July 28, 2022, and by the inspectors assigned to this AEPD, through a diligence incorporated into this file on January 27, 2023, that once a user has registered on the website ***WEB.1, and with the mere introduction of the email with which they registered on the website ***URL.2, it is possible to access their personal data (name and surname, email, date of birth, postal code, and country). That is, access to this personal data is obtained without the need to enter any other information apart from the email.

These facts could constitute a violation of Article 32 of the GDPR, given that appropriate measures have not been adopted to prevent unauthorized access, such as measures to ensure the proper identification and authentication of users.

It should be noted that the GDPR does not establish a list of security measures applicable according to the data being processed, but rather, under the principle of proactive responsibility of Article 5.2 of the GDPR itself, which entails the requirement that the data controller ensure the effective privacy and integrity of the data, both the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects. Furthermore, the controller must be in a position to demonstrate that they have implemented these measures and that they are adequate to achieve the intended purpose.

Additionally, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical measures and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/24

Organizational measures must be carried out taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which are particularly likely to cause physical, material, or immaterial damage.”

For all the above reasons, the technical and organizational measures applied by EMAILING NETWORK EUROPE do not guarantee an adequate level of security in relation to the risk, as required

by Article 32 of the GDPR, insofar as they do not allow for verification that those accessing the data are authorized. Therefore, it is concluded that EMAILING NETWORK EUROPE has not implemented any measures that would prevent unauthorized access.

For all these reasons, in accordance with the evidence available at this moment regarding the initiation of sanctioning proceedings, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to EMAILING NETWORK EUROPE for violation of Article 32.

IX

Classification of the infringement of Article 32

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/24

In the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the data controller and the data processor in accordance with Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Serious Infringements" of the LOPDGDD indicates:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679. (...)"

VIII

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected individuals and the level of damage and harm they have suffered (paragraph a): for putting at risk and failing to have appropriate measures to ensure the security of the data of individuals registered on the website ***WEB.1, (as indicated: 8812 active users from Spain (and 412919 inactive users); 5112 active users in Italy (and 148364 inactive users); 667 active users in France (and 31788 inactive users), considering that, since at least February 14, 2021, the date on which the complaint was received by the CNIL, until at least January 27, 2023, the system for accessing the profile had not been corrected.
- Intentionality/Negligence in the infringement (paragraph b): In this case, EMAILING NETWORK EUROPE would have acted very negligently, since, from at least February 14, 2021, the date of entry of the complaint, until January 27, 2023, the date of the last check, almost two years would have

passed without the correct measures being adopted to ensure security and prevent the loss of confidentiality of the personal data owned by the data controller.

Furthermore, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- The link between the infringer's activity and the processing of personal data (paragraph b): it is an entity accustomed to processing personal data.

As mitigating factors:

- Having, when not mandatory, a data protection officer (paragraph g).

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 32 of the GDPR, allows for an initial sanction of €10,000 (ten thousand euros).

IX

Imposition of measures

If the infringement is confirmed, it could be agreed to impose on the controller the obligation to adapt its website within 60 days so that it is not possible to access the data of registered individuals by simply entering an email address when accessing the website ***URL.2, as already indicated, without prejudice to others that may arise from the instruction of the procedure, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Furthermore, the measures that may be adopted in the resolution that concludes the procedure would apply in all countries of the European Union where EMAILING NETWORK EUROPE operates.

It is warned that failure to comply with the requirements of this body could be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which could motivate the opening of a further administrative sanctioning procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/24

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against EMAILING NETWORK EUROPE, S.L., with NIF B64649957:

- for the alleged infringement of Article 25 of the GDPR, classified under Article 83.4 of the GDPR.
- for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

SECOND: TO APPOINT A.A.A. as the instructor and B.B.B. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the documentation from the IMI that has led to the preliminary investigation actions, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the preliminary actions prior to the initiation of this sanctioning procedure and the documentation from the IMI regarding the draft decision.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be:

- For the alleged infringement of Article 25 of the GDPR, classified under Article 83.4 of that regulation, an administrative fine of 10,000 euros.
- For the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of that regulation, an administrative fine of 10,000 euros.

FIFTH: TO NOTIFY this agreement to EMAILING NETWORK EUROPE, S.L., with NIF B64649957, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

If no allegations are made within the stipulated period regarding this initiation agreement, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 16,000 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 16,000 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be set at 12,000 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction.

In the event that it opts to proceed with the voluntary payment of either of the amounts indicated above (16,000 euros or 12,000 euros), it must make the payment by depositing it into account no. IBAN: ES00-0000-0000-0000-0000 opened in the name of the Spanish Agency for Data Protection at the bank CAIXABANK, S.A., indicating in the concept the reference number of the file that appears in the heading of this document and the reason for the reduction of the amount to which it is entitled. Furthermore, it must send the proof of payment to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGGDD.

In compliance with Articles 14, 41, and 43 of the LPACAP, it is warned that, henceforth, notifications sent to it will be made exclusively electronically, through the Single Enabled Electronic Address (dehu.redsara.es) and the Electronic Notification Service (notificaciones.060.es), and that, if it does not access them, its rejection will be recorded in the file, considering the procedure completed and continuing with the process. It is informed that it can identify an email address to this Agency to receive the notice of availability of notifications and that the lack of practice of this notice will not prevent the notification from being considered fully valid.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/24

Finally, it is noted that in accordance with the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-030423

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On June 16, 2023, the respondent has proceeded to pay the fine in the amount of 12,000 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility in relation to the facts referred to in the Initiation Agreement.

FOURTH: The previously transcribed Initiation Agreement indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the Initiation Agreement is warranted.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

In accordance with the above,
the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202202685, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER EMAILING NETWORK EUROPE, S.L. to notify the Agency within one month of the adoption of the measures described in the legal grounds of the Initiation Agreement transcribed in this resolution.

THIRD: TO NOTIFY this resolution to EMAILING NETWORK EUROPE, S.L.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1259-121222

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es